Prepared by: Shreyank Upadhyay,
Role: Independent Security Researcher,
S0864074@gmail.com
+91 7003744033

WANNA CRY RANSOMWARE ATTACK ANALYSIS

EXECUTIVE SUMMARY

This report analyzes the WannaCry ransomware attack (12 May 2017) as part of a portfolio demonstrating practical skills in cyber-attack analysis, threat intelligence, and SOC-level incident response.

WannaCry infected 300,000+ systems across 150 countries within hours, causing $4billion+ (est.) in damages. It exploited CVE-2017-0144, a critical SMBv1 vulnerability. Microsoft had released patch MS17-010 59 days earlier. Most organizations did not patch. This failure allowed WannaCry to spread automatically using EternalBlue and DoublePulsar, with no user interaction.

The UK's NHS lost 70,000 devices and £92 million. Other victims included Renault-Nissan, Telefónica, FedEx, and Deutsche Bahn.

What This Covers: Attack timeline, technical execution, detection with KQL/Splunk queries, full IOCs (hashes, domains, registry keys, mutex names), MITRE ATT&CK mapping, IR procedures, and prevention architecture.

Key Takeaways: Patch within 48 hours, disable SMBv1, segment networks, maintain offline backups, and correlate alerts.

Written for SOC and CTI junior analysts with practical enterprise examples.

TABLE OF CONTENT

EXECUTIVE SUMMARY 2
TABLE OF CONTENT 3
1. OVERVIEW 3
2. TIMELINE OF ATTACK 5
3. HOW ATTACKER EXECUTED THE ATTACK 6
4. VULNERABILITY ANALYSIS & EXPLOITATION MECHANISM 19
5. ATTACK WORKFLOW 22
6. ORGANIZATIONAL IMPACT 23
7. DETECTING & MONITORING OF WANNACRY 25
8. INCIDENT RESPONSE & IMMEDIATE MITIGATION 45
9. IDEAL PREVENTION ARCHITECTURE 49
10. MITRE ATT&CK MAPPING & DETECTION INSIGHTS 52
11. KEY LEARNINGS 65
12. INTELLIGENCE ASSESSMENT 69
13. REFERENCES 71

1. OVERVIEW

The WannaCry ransomware attack was a large-scale global cyberattack that started on 12 May 2017. It mainly targeted Microsoft Windows operating systems, especially older and unpatched systems like Windows XP and Windows 7. WannaCry is known as a ransomware cryptoworm because it not only encrypts files but also spreads automatically across networks without user interaction.

The malware encrypted files on infected systems and demanded a ransom of around $300 to $600 in Bitcoin to restore access. Even though the attack spread to more than 300,000+ systems across 150+ countries, the total ransom collected was relatively low, around $130,000. However, the overall global damage was very high, $4billion+ (est.) due to downtime, operational disruption, and system recovery costs.

WannaCry spread using a vulnerability in the SMBv1 protocol, identified as CVE-2017-0144. It used the EternalBlue exploit to gain access to systems and then used the DoublePulsar backdoor to execute the ransomware payload and continue spreading. This made the attack very fast and dangerous because it did not require users to click anything once inside a network.

Microsoft had already released a patch for this vulnerability (MS17-010) on 14 March 2017, but many organizations had not updated their systems. Because of this, a large number of systems remained vulnerable, which allowed WannaCry to spread quickly across networks and even between countries.

The attack has been attributed to **Lazarus Group (assessed with moderate-to-high confidence)** by multiple vendors (NSA, GCHQ, Microsoft), with **suspected ties to the DPRK (assessed with moderate confidence)**. This group is known for financially motivated cyber operations, and WannaCry is believed to be used mainly for generating money through ransomware, even though the financial gain was not very high compared to the damage caused.

The attack happened shortly after the Shadow Brokers leaked cyber tools, including EternalBlue, which was originally developed by the NSA. This shows how powerful tools developed by governments can be misused when leaked and used in real-world attacks.

WannaCry affected many countries including Russia, India, China, and Ukraine. One of the most serious impacts was seen in the United Kingdom's National Health Service (NHS), where hospitals had to cancel appointments and shut down systems. Other major companies affected include Renault, Telefónica, and FedEx.

Overall, WannaCry is one of the most important cyberattacks to study because it clearly shows how unpatched systems, outdated protocols like SMBv1, and weak network security can lead to a massive global incident in a very short time.

---

2. TIMELINE OF ATTACK

Date & Time (UTC)	Event
2017-03-14	Microsoft releases MS17-010 patch fixing CVE-2017-0144
2017-04-14	Shadow Brokers publicly leaks EternalBlue and DoublePulsar
2017-05-12 (~07:44)	First infections detected, NHS UK among the earliest major victims.
2017-05-12 (07:44–15:03)	Global impact grows to 150+ countries via SMBv1 exploitation.
2017-05-12 (~15:03)	Marcus Hutchins registers kill switch domain, slowing spread.
2017-05-12	Microsoft releases emergency patch for end-of-life Windows XP, Server 2003
2017-05-13	FedEx, Renault, Telefónica confirms systems encrypted.
2017-05-14-16	Global post-incident analysis, attribution investigation begins.

- **<u>Security Insights (SOC/CTI Perspective)</u>**
- **2017-03-14: MS17-010 Patch Released:** Critical RCE fixed; unpatched systems create high-risk exposure window.

- **2017-04-14 – Shadow Brokers Leak (EternalBlue, DoublePulsar):** Nation–state exploit became public → weaponization barrier removed.

- **2017-05-12 (~07:44) – First Infections Detected (NHS UK):** Active exploitation begins → SOC should monitor SMB anomalies (port 445).

- **2017-05-12 (07:44–15:03) – Rapid Global Spread (150+ countries):** Worm propagation → detection window extremely short, requires automated response.

- **2017-05-12 (~15:03) – Kill Switch Activated:** External propagation slowed, but internal infections continue.

- **2017-05-12 – Emergency Patch for Legacy Systems (XP/2003):** Confirms severity → legacy systems identified as critical risk.

- **2017-05-13 – Major Enterprises Confirm Impact (FedEx, Renault, Telefónica):** Business disruption phase → indicates widespread lateral movement success.

- **2017-05-14–16 – Post-Incident Analysis & Attribution Begins:** Shift to IR + CTI → IOC sharing and detection rule development.

---

3. HOW ATTACKER EXECUTED THE ATTACK

This section analyzes the WannaCry attack across three intelligence dimensions. At the strategic level, it examines the threat actor's motivation and campaign context. At the operational level, it covers how the attack was executed and how it spread. At the tactical level, it maps specific TTPs, indicators, and detection opportunities that defenders can act on. Together, these three layers provide a complete picture of the attack from a CTI perspective.

In this section, I will walk through each stage of the attack step by step — from initial access to propagation and encryption — to understand how WannaCry executed so efficiently.

• Attack History and Design: -

WannaCry is a ransomware crypto-worm that targets Microsoft Windows systems. It locks user files and asks for ransom payments in Bitcoin. Because it is a network worm, it can spread automatically to other vulnerable systems using the SMB protocol. Versions 0, 1, and 2 were made using Microsoft Visual C++ 6.0, showing that the attack relied on older coding tools.

The attackers used two main tools released by The Shadow Brokers. **EternalBlue** is an SMB exploit created by the U.S. NSA that allows remote code execution on unpatched systems, even though Microsoft had released the MS17-010 patch on 14 March 2017. **DoublePulsar** is a backdoor released on 14 April 2017, which had already infected many computers. WannaCry used it to copy itself and run across networks.

When the malware ran, it first checked a **kill-switch domain (iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com)**. If the domain was not registered, it started encrypting files right away. It also extracted binaries, hid folders, changed security settings, deleted shadow copies, and created encryption keys. Victims saw a message asking for about **$300 in Bitcoin within three days, which went up to $600 after seven days**, sent

to three fixed wallets. At the same time, the worm scanned other vulnerable systems on the Internet and in local networks, using EternalBlue and DoublePulsar to spread itself.

The first known infection happened on **12 May 2017 at (07:44 UTC)** and it lasted till **12 May 2017 (13:03 UTC)**, probably through open SMB ports rather than phishing. Within one day, more than **300,000+ computers in over 150 countries were affected**. Systems without the March patch, or unsupported versions like Windows XP and Server 2003, were at the highest risk. Windows 7 made up 98% of the infected computers. The fast spread and use of pre-existing backdoors showed how efficient the worm was and why keeping systems patched is very important in real enterprise environments.

• Key Details: -

- **Attack Type:** Ransomware (Crypto Worm).
- **Initial Access Vector:** Exploitation of SMBv1 vulnerability (no user interaction).
- **Vulnerability:** CVE-2017-0144 (MS 17-O1O).
- **Exploit Used:** EternalBlue.
- **Protocol:** SMBv1.
- **Port:** TCP 445.
- **Target Systems:** Unpatched Windows System (Windows7, Xp, Server 2003).
- **Propagation Method:** Self-propagating worm (lateral movement via network).
- **Execution method:** Remote Code execution via SMB exploit.
- **Kill Switch:** Hardcoded domain used to stop execution.
- **Impact:** File Encryption + ransomware demand in Bitcoin.
- **Ransom Amount:** ~$300 – ~$600.
- **Scale of attack:** 230k+ systems, across 150+ countries.

• Attack Workflow:

Here, I will discuss the detail attack workflow of WannaCry with initial access to exploitation, automated propagation and ransomware impact to create one of the fastest spreading cyberattacks in history.

3.1. Initial Exploitation: The initial infection vector remains unconfirmed. Microsoft found no forensic evidence to determine how the first system was infected. The primary hypothesis, supported by the absence of phishing evidence and the prevalence of internet-exposed port 445 systems in affected regions, is direct SMB exploitation. Phishing remains a secondary hypothesis with no supporting forensic evidence.

Two possible scenarios have been identified by Security Analysts are:

- **Social Engineering Email (Potential)**

- **Description:** Users may have been tricked into opening malicious email attachments, which executed the malware and activated its worm-spreading functionality.
- **Execution Mechanism:** User opens attachments → malware executes → worm propagation activated.

- **<u>MITRE ATT&CK TTPs:</u>**
- **T1566 – Phishing:** Email-based delivery of malicious content.
- **T1204 – User Execution:** Execution depends on user action.
- **T1059 – Command and Scripting Interpreter** (if attachments contain macro/script).

- **SMB Exploit (Propagation Confirmed)**

- **Description:** Direct network infection through the smbv1 vulnerability (CVE-2017-0144) on unpatched systems, allowing malware to spread without users' interactions.
- **Execution Mechanism:** Malware remote connects → loader runs on victim system → worm propagation starts.

MITRE ATT&CK TTPs:

- **T1210 – Exploitation of Remote Services:** Using SMBv1 vulnerability for remote code execution.

Note: Both entry paths ultimately allow the malware to gain execution on the victim's system and proceed to the next stages of its attack workflow, including kill-switch check and ransomware propagation. CISA confirms the dropper installs as a service (mssecsvc2.0) and scans local networks for SMB targets.

3.2. Payload Injection / Backdoor Deployment:

After the initial exploitation via EternalBlue for remote code execution, the attacker leverages the DoublePulsar backdoor to inject the ransomware loader into memory, establishing a controlled execution environment and enabling persistence for subsequent payload deployment.

- **Execution Flow:**

- **Kernel-Level Access via EternalBlue:**
- Post initial exploitation, the malware triggers the SMBv1 memory corruption to achieve remote code execution (RCE) with kernel-level privileges.
- This allows execution without user context or privileges.
- **TTP: T1210** – Exploitation of Remote Services.

- **DoublePulsar Injection:**
- Loads as kernel-mode implant to act as an in-memory backdoor.
- DLL payload injected into user space, enabling tasksche.exe dropper execution.
- Provides persistence in memory, avoiding disk-based detection.
- **TTP: T1055.001** - Process Injection: Dynamic-link Library Injection.

- **Dropper Deployment (tasksche.exe / mssecsvc.exe):**
- Dropper written to disk in hidden system directories.
- Executed via DoublePulsar to establish local control.
- Initiates environment setup for encryption and lateral movement.
- Detection: Event ID 4688 (Process-Creation), unusual write to C:\Windows\

- **Backdoor Capabilities**
- Enables remote command execution, file copying, and worm propagation triggers.
- Maintains execution in RAM to avoid AV signature scans.

3.3. Loader Execution & Persistence Establishment:

After successful exploitation via EternalBlue and payload injection through DoublePulsar, WannaCry establishes execution on the compromised host. In this stage, the malware deploys its components, creates persistence, and prepares the system for kill-switch verification and subsequent ransomware execution.

Execution & Actions:

1. Component Drop & Local Execution:
The injected payload writes ransomware components to disk, primarily:

- **C:\Windows\tasksche.exe** → (ransomware execution binary).
- **Mssecsvc.exe** → (worm / propagation component).

These binaries are executed to establish local control and initiate the attack workflow.

Detection Opportunities:

- Windows Event ID **4688** (process creation)
- Execution of binaries from `C:\Windows\` directory

MITRE ATT&CK TTP: T1105 – Ingress Tool Transfer (payload delivery to host)

2. Service Creation for Persistence:
WannaCry installs a Windows service named mssecsvc2.0, with the display name "Microsoft Security Center (2.0) Service."
This service is configured to start automatically, ensuring persistence across system reboots.
The naming convention mimics legitimate Microsoft services to reduce suspicion.

MITRE ATT&CK TTP: T1543.003 – Create or Modify System Process: Windows Service

3. File & Directory Manipulation (Defense Evasion):

The malware hides and protects its artifacts using native Windows utilities:

- Uses **attrib +h** to hide files and directories.
- Uses **icacls** ./grant Everyone: F/T/C/Q to grant full permissions to all users, preventing removal and resisting AV cleanup attempts.

These actions reduce visibility and hinder removal.

MITRE ATT&CK TTPs:

- **T1564.001** - **Hide artifacts:** Hidden files and directories.
- **T1222.001 -** Fie and Directory Permissions Modification.

4. Execution Stabilization

The malware maintains active execution through the created service and associated process, ensuring continuity as it proceeds to kill-switch verification and ransomware activity.

Detection Opportunities:

- Event ID 7045 (service creation: mssecsvc2.0).
- Persistent suspicious processes running from system directories.

Note: This stage marks the transition from remote code execution to full system compromise. At this point, WannaCry has established persistence, deployed its payload, and secured reliable execution. The system is now prepared for kill-switch validation and subsequent ransomware execution.

3.4. Kill-Switch Domain Verification:

After loader execution and persistence establishment, the ransomware module performs a pre-execution check by querying a hardcoded kill-switch domain

Execution & Actions:

- **Kill-Switch Domain Verification**

  Malware sends an HTTP request to hardcoded kill-switch domain (iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com).

  Decision Flow:
- Domain Reachable (HTTP Success): Execution stops, ransomware does not proceed.
- Domain Not Reachable (Connection Fails): Attack continues → Loads ransomware and worm modules.

  Purpose: Anti-analysis / Sandbox evasion. Many automated analysis environments would have those domains reachable, preventing execution.

- **Impact / Observation:**
- Researchers registering the domain later inadvertently slowed the global spread.
- Confirms malware checks external network conditions before full execution.

- **MITRE ATT&CK TTP: T1497.001 - System Checks** (sanbox evasion via environment check)

- **Detection Opportunities:**
  - DNS query or HTTP GET request to (iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com**)**
  - Early-stage stop/fail behaviors combined with service creation (mssecsvc2.0) may indicate pre-execution checks.
- **Kill-Switch-Domain Check Flow**

```
            [Kill-Switch Domain Check]
                        ↓
Domain Reachable        |        Domain Not Reachable
  (HTTP Success)        |          (Connection Fails)
```

└──┘

↓ ↓

[Stop Execution] [Continue Attack]

↓

[Load Worm + Ransomware]

Note: This stage occurs before ransomware payload execution, controlling whether the malware proceeds further and thus acting as a pre-execution control point in the attack workflow.

3.5. Ransomware Execution (Encryption Phase)

After successful loader execution and kill-switch verification, WannaCry transitions into primary impact phase — data encryption and availability disruption. This stage is responsible for rendering users and enterprise data inaccessible while enforcing ransom payment.

Execution & Actions

1. Shadow Copy Deletion (Recovery Inhibition)

WannaCry disables all Windows recovery mechanisms before encryption begins, maximizing ransom leverage.

- **Executes:**
  vssadmin delete shadows /all /quiet
- Removes Volume Shadow Copies and backup history.

Detection Opportunities:

- Process execution: vssadmin.exe with delete shadows.
- Command-line monitoring (Sysmon Event ID 1 / EDR telemetry).

MITRE ATT&CK: T1490 – Inhibit System Recovery

2. File Targeting & Enumeration

The malware scans the filesystem to identify high-value user and enterprise files.

- Targets over 170 file extensions including:

.doc, .xls, .ppt, .jpg, .zip, .vmdk ,.pdf, .mp4, .sql, .raw, .avi

- Traverses all local drives and accessible network directories, prioritizing user documents, database files, virtual machine images, and media files.

Detection Opportunities:

- Abnormal file access patterns across multiple directories
- High-volume file enumeration activity

MITRE ATT&CK: T1083 – File and Directory Discovery

3. File Encryption (Core Impact)

WannaCry encrypts files using a hybrid cryptographic model.

- AES-128-CBC → encrypts file content.
- RSA-2048 → encrypts AES keys.

Encrypted files are renamed with extensions:

- .WNCRY, .WCRY, .WNCRYT

Without the attacker's private RSA key, decryption is computationally infeasible.

Critical CTI Insight:

WannCry's implementation contained a flaw in its RSA key generation on certain Windows XP and Windows 7 systems. It failed to properly clear prime numbers used in RSA key derivation from process memory after generation. Researcher Adrien Guinet discovered this in May 2017, and Benjamin Delpy released WannaKiwi – a tool that could recover the encryption key from memory and enable decryption without paying ransom. This only worked on systems running Windows XP, Vista, 7, Server 2003, or Server 2008 that had NOT been rebooted since infection. Rebooted systems had no working free decryptor

Detection Opportunities:

- Rapid file modification rate
- File extension changes across directories
- High disk I/O activity

MITRE ATT&CK: T1486 – Data Encrypted for Impact

4. Ransom Note Deployment & User Interaction

After encryption, WannaCry deploys a ransom interface:

- Executable: @WanaDecryptor@.exe
- Drops ransom note: !Please Read Me!.txt

Displayed content includes:

- Payment demand (~$300 → ~$600 in Bitcoin)
- Countdown timer
- Payment instructions

Detection Opportunities:

- Execution of @WanaDecryptor@.exe
- Creation of ransom note files across directories

MITRE ATT&CK: T1491.001 – Defacement: Internal Defacement (ransom UI display)

5. Parallel Propagation Continuation (Critical Behavior)

WannaCry does not wait for encryption to finish.

- Propagation continues in parallel with encryption.
- Infected host continues scanning and exploiting other systems.

This enables **exponential spread during active encryption phase**.

Detection Opportunities:

- Simultaneous:
- File encryption activity
- Outbound SMB scanning (TCP 445)

Analyst Note: This phase represents the maximum business impact stage, where:

- Availability is completely disrupted.

- Recovery options are intentionally destroyed.
- Lateral spread continues simultaneously.

The combination of encryption + worm propagation + recovery inhibition is what made WannaCry operationally devastating in enterprise environments.

3.6. Worm Propagation & Self-Spreading Loop:

After establishing execution and initiating encryption, WannaCry continuously propagates across networks using an automated, multi-threaded worm mechanism. This stage is responsible for large-scale lateral movement and rapid global spread.

Propagation Mechanism

WannaCry operates two operates two simultaneous scanning threads running in parallel with encryption – not sequentially after it:

- **Thread 1 – Local Subnet Scan:** Enumerated all IP addresses on the infected host's LAN segment, attempting TCP 445 connections to internal systems.
- **Thread 2 – Gblobal Internet Scan:** Generates random internet-facing IP addresses and attempts TCP 445 connections, enabling cross-country propagation without any central co-ordination.

Each thread attempts connections to TCP port 445 (SMB) on remote systems.

Multi-threaded design enables thousands of connections of attempts per minute. This parallel architecture – encryption and propagation running simultaneously – is the primary reason 300k+ systems were compromised within approximately 7 hours on a single day.

When a vulnerable system is identifies:

- The malware exploits the SMBv1 vulnerability using EternalBlue to achieve unauthenticated remote code execution.
- DoublePulsar is then used as a kernel-level implant to inject and execute the ransomware payload on the target system.
- The ransomware binary is deployed and executed, repeating the infection cycle on the new host.

On each compromised system:

- Persistence is established via the mssecsvc2.0 service.
- Shadow copies are deleted to prevent recovery.
- Files are encrypted and renamed with WannaCry-specific extensions.
- A ransom message is displayed to the victim.

Propagation continues in parallel with encryption, allowing simultaneous spread and impact.

Execution Loop (Core Behavior)

Scan → Identify Target → Exploit (EternalBlue) → Inject (DoublePulsar) → Deploy Payload → Execute → Repeat.

This loop runs continuously until no further vulnerable systems are reachable.

Detection Opportunities

- High-volume outbound SMB connections (TCP 445)
- East-west traffic spikes within internal networks
- Repeated service creation (mssecsvc2.0) across endpoints

Simultaneous:

- File encryption activity
- Network scanning behavior

MITRE ATT&CK Mapping

- **T1046 – Network Service Discovery (scanning for SMB services)**
- **T1210 – Exploitation of Remote Services (EternalBlue)**
- **T1055.001 – Process Injection (DoublePulsar payload execution)**
- **T1105 – Ingress Tool Transfer (payload delivery to new hosts)**
- **T1543.003 – Create or Modify System Process: Windows Service**
- **T1021.002 – Remote Services: SMB/Windows Admin Shares**
- **T1486 – Data Encrypted for Impact**
- **T1490 – Inhibit System Recovery**
- **T1491 – Defacement (ransom note / UI display)**

Analyst Notes

- WannaCry propagation is fully automated and does not require user interaction.
- Multi-threaded scanning enables thousands of connection attempts per minute, leading to exponential spread.
- Encryption and propagation occur in parallel, not sequentially.
- Each infected host becomes a new propagation node, amplifying network-wide impact.

Key CTI Insight

WannaCry's effectiveness comes from combining:

- Exploit (EternalBlue)
- Backdoor (DoublePulsar)
- Payload (Ransomware)

into a self-sustaining propagation loop, making it one of the fastest-spreading ransomware attacks observed in enterprise environments.

Note: This stage initiates at section 3.3 and runs continuously in parallel with all subsequent stages, including encryption. It is presented here for clarity but is not sequential to section 3.5

---

4. VULNERABILITY ANALYSIS & EXPLOITATION MECHANISM

OVERVIEW: In this section, I will analyze the main vulnerability that made the WannaCry attack possible. I will explain how the weakness in the SMBv1 protocol was exploited, why it was dangerous, and how it led to remote code execution and rapid ransomware spread across networks. This will help to clearly understand the connection between the vulnerability, exploit, and the overall attack impact.

4.1. Vulnerability Overview:

WannaCry exploited a critical remote code execution vulnerability in the Microsoft Windows SMBv1 protocol, tracked as CVE-2017-0144. The vulnerability is rated **9.3 (Critical)** under CVSS v2 and **8.8 (High/Critical)** under CVSS v3, reflecting its high impact on confidentiality, integrity, and availability due to unauthenticated remote exploitation capability. This flaw allowed attackers to send specially crafted packets to systems with SMBv1 enabled, resulting in **unauthenticated remote code execution**. According to **CISA**, the vulnerability affected multiple Windows versions, including Windows XP, 7, and Server 2003, and was publicly disclosed after **The Shadow Brokers** leak. Unpatched systems exposed over **TCP port 445** were at the highest risk, enabling WannaCry to propagate as a **self-spreading ransomware worm** across networks.

4.2. Technical Explanation:

The WannaCry attack exploited a vulnerability in SMBv1, a very old Windows file-sharing protocol. The problem happens because SMBv1 does not handle specially crafted packets properly, which leads to a heap **buffer overflow in SMBv1 transaction processing**. Attackers send these malicious packets to port 445, which is used for SMB traffic. When the packets are processed, memory is overwritten, allowing attackers to run any code on the system without logging in.
The exploit called EternalBlue uses this flaw to take control of the system. It carefully creates packets that overwrite memory and inject code, which then executes automatically. Once it runs, it can install ransomware, move across the network, and infect other computers that also have SMBv1 enabled and exposed on port 445. This makes the vulnerability very dangerous because it allows unauthenticated remote code execution and automatic spreading.

4.3. Root Cause:

The WannaCry attack was able to spread and cause damage because of several key technical weaknesses in affected systems:

- **SMBv1 was enabled:** Many systems were still running the old SMBv1 protocol, which has known security flaws. This outdated protocol made it easier for attackers to access computers remotely.
- **Missing security updates:** Microsoft had released the MS17-010 patch to fix CVE-2017-0144, but many systems did not install it. Without this patch, attackers could exploit the vulnerability to execute code on computers without any authentication.
- **Exposed systems on port 445:** The SMB service was reachable from the network on TCP port 445. Attackers could directly connect and exploit unpatched systems, allowing fast infection across networks.
- **Poor network segmentation:** Networks were not properly divided into secure zones. Once one system was infected, the malware could move easily to other computers on the same network.
- **No detection of abnormal SMB traffic:** Many organizations did not have intrusion detection systems or monitor unusual SMB activity. This lack of monitoring allowed the malware to spread without early alerts.

4.4. Patching:

The WannaCry ransomware exploited a critical vulnerability in the SMBv1 protocol, identified as **CVE-2017-0144.** Microsoft addressed this flaw with the security update **MS17-010**, released on 14 March 2017. The patch corrected the improper handling of packets in SMBv1, which previously allowed remote code execution without authentication. Systems that applied this update prior to the attack were immune to WannaCry, as the EternalBlue exploit could no longer succeed against patched machines.

The **CVE database classifies** CVE-2017-0144 as a critical vulnerability, highlighting the risk of unauthenticated remote code execution. Any system that remained unpatched after the vulnerability was publicly disclosed remained fully exposed to exploitation.

The **Cybersecurity and Infrastructure Security Agency (CISA)** recommended that organizations not only apply MS17-010 but also disable SMBv1 if it was not required. CISA

emphasizes that exposing SMB services over the network, especially on TCP port 445, significantly increases the risk of compromise.

Key protection step includes applying MS17-010 on all supported Windows systems to block the EternalBlue exploit.

Organizations that applied MS17-010 prior to May 12, 2017, were fully protected against WannaCry. This highlights that timely patch management is the single most effective defense against known vulnerability exploitation

4.5. Vulnerability–Exploit–Attack Chain:

WannaCry's destruction was not caused by one thing alone – it was the result of a connected chain where each stage enabled the next.

The chain flows as follows:

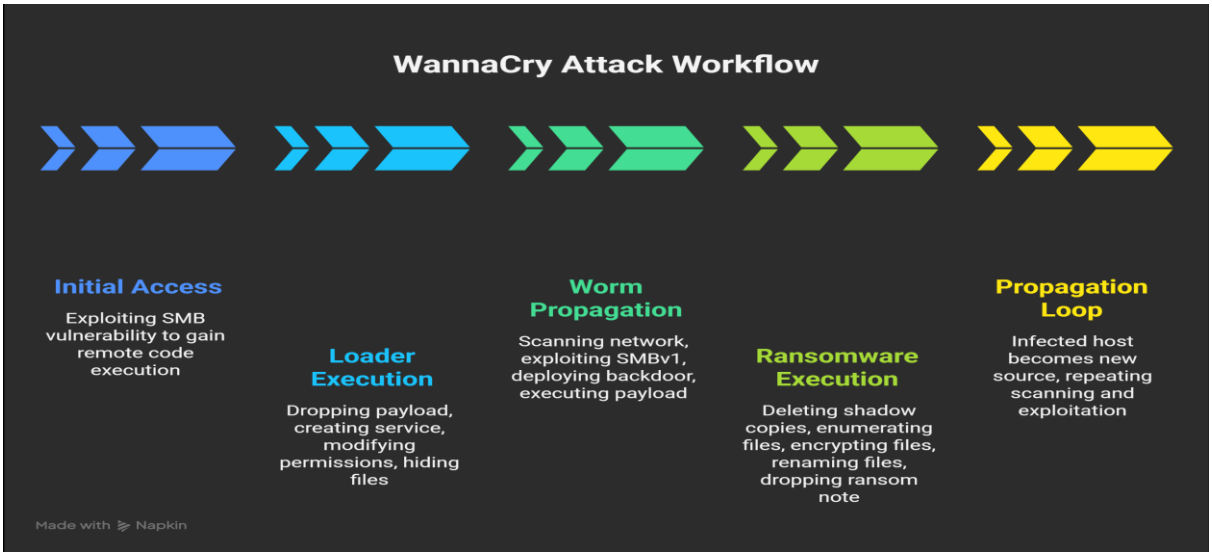
Vulnerability (CVE-2017-0144) → SMBv1 flaw in unpatched Windows systems → Exploit (EternalBlue) → malicious SMB packets delivered over TCP port 445 → Initial Access → Remote Code Execution achieved without authentication → Backdoor (DoublePulsar) → payload delivered and executed on victim system → Result → Worm propagation across networks + Ransomware deployment + File encryption.

Understanding this chain makes it clear why WannaCry spread so fast. There was no user interaction needed, no phishing required, and no warning given. One unpatched port facing the network was enough for the entire chain to execute automatically – from initial exploitation to full encryption – within minutes on each new host.

---

5. ATTACK WORKFLOW

The following diagram illustrates the complete WannaCry attack workflow from initial access through propagation and encryption. Each stage connects directly to the next — beginning with SMB exploitation via EternalBlue, through the kill switch check, loader execution, persistence creation, and finally file encryption and the self-propagating worm loop. This end-to-end flow demonstrates why WannaCry requires no user interaction to achieve global-scale infection within hours.



---

6. ORGANIZATIONAL IMPACT

OVERVIEW: The WannaCry ransomware attack caused widespread disruption across multiple sectors, demonstrating the significant technical and business consequences of unpatched vulnerabilities, including system downtime, data encryption, financial losses, and operational interruptions.

6.1. Technical Impact:

- **System Downtime:**
- 300,000+ computers were infected globally. Critical systems like NHS hospital devices, MRI scanners, manufacturing plant controllers, and telecom servers were unavailable.
- Legacy OS and unpatched Windows systems (XP, 7, Server 2003/2008) were fully compromised.
- **Data Encryption & Access Loss:**
- Files encrypted with ransomware, causing full **loss of access to critical data.**
- Backdoors installed in some systems, requiring deep forensic cleanup.
- **Rapid Propagation**
- Exploited **EternalBlue (MS17-010)** SMBv1 vulnerability.
- Spread automatically via internal networks (port 445 scanning), exploiting weak segmentation.

6.2. Business Impact:

- **Financial Losses:**

Global losses were estimated at $4 billion.

- **NHS:** £ 92 million (~19,000 appointments canceled).
- **Telefónica**: 85% of internal computers affected; employees instructed to shut down systems; $550,000 in Bitcoin demanded (not paid).
- **FedEx, Renault-Nissan:** production halted, shipment delays, operational disruption.

- **Operational Disruption:**
- **NHS:** Ambulances diverted; non-critical surgeries canceled.
- **Renault-Nissan:** Five plants halted (France, Romania, Slovenia, India).
- **Deutsche Bahn:** Passenger info displays affected, though trains ran.
- **MegaFon:** Internal network disruption across Russia.

- **Reputation & Regulatory Risk:**
- Highlighted patching failures, weak internal controls, and exposure of legacy systems.
- Healthcare and finance sectors faced potential compliance breaches (GDPR/HIPAA).

Real-World Cases / Sector-Specific Impact

Sector	Organization	Impact
Healthcare	NHS UK	70,000 devices affected, 19,000 appointments canceled, ambulance rerouting, £92 million damage
Automotive	Renault-Nissan	Production halted at 5 plants, temporary shutdowns, recovery in 2–3 days
Telecom	Telefonica (Spain), MegaFon (Russia)	Internal systems encrypted, operations disrupted across Spain and Russia.
Transportation	Deutsche Bahn (Germany)	450 computers affected; station display boards hijacked displaying ransom messages. Train services continued without disruption, though recovery required significant repair and overtime efforts
Finance	Bank of China, Sberbank	ATM & network disruptions; contained due to patching and IT defense systems

Note: Analysis of this attack reveals that, although WannaCry's active spread was contained within approximately 10 hours through the kill switch, the resulting damage was catastrophic — estimated at $4 billion+ USD in global losses over several weeks of downtime and recovery. Organizations across healthcare, telecom, automotive, and finance were directly affected, including NHS, Renault-Nissan, Telefónica, and MegaFon. This demonstrates how a single unpatched vulnerability can rapidly escalate into massive operational and financial disruption.

---

7. DETECTING & MONITORING OF WANNACRY

Detection of WannaCry relies on identifying abnormal SMB activity, rapid file encryption behavior, and exploiting signatures across endpoints and network telemetry. A SOC analyst correlates with SIEM logs, EDR alerts, and network IDS signals to confirm exploitation and lateral movement.

The following table represents a reconstructed SOC detection timeline based on known WannaCry attack behavior. It illustrates the sequence of events a SOC analyst would observe across log sources during an active infection.

Time (UTC)	Stage	Event	Log Source	Event ID	Detection Signal
07:44	Initial Access	SMB exploit attempt on port 445	Firewall/IDS	–	High volume SYN packets on TCP 445
07:45	Execution	tasksche.exe dropped and executed	Windows Event Log	4688	Non-standard binary in C:\Windows\
07:45	Persistence	mssecsvc2.0 service created	Windows Event Log	7045	Suspicious service mimicking Microsoft
07:46	Defense Evasion	attrib +h hides malware files	Sysmon	1	Hidden file attribute set on malware
07:46	Defense Evasion	icacls modifies file permissions	Sysmon	1	Permission change on system files
07:47	Impact	vssadmin delete shadows executed	Sysmon	1	Shadow copy deletion – ransomware signal
07:47	Impact	Mass file encryption begins	Sysmon	11	Rapid .WNCRY extension changes
07:48	Lateral Movement	SMB scanning resumes to new targets	Network/IDS	–	Port 445 scanning to new IP ranges

7.1. SIEM-Based Detection (Log Analysis & Correlation Layer):

Siem-based detection focuses on identifying WannaCry activity through log correlation, abnormal process execution, service creation, and file system changes across infected endpoints.

Log Sources Used:

- Windows Event Logs
- Sysmon Logs
- Security Logs

1. Malicious Service Creation Detection

WannaCry establishes persistence by creating a malicious Windows service.

- **Event ID:** 7045 (Service Creation)
- **Indicators:**
- **Service Name**: mssecsvc2.0
- **Display Name**: Microsoft Security Center (2.0).
- **Detection Logic:**

  Monitor newly created services with suspicious or non-standard names, especially those mimicking legitimate Microsoft services.

  Example SIEM Query (Conceptual):

  Event ID = 7045 AND Service Name = "mssecsvc2.0"

2. Malicious Process Creation Detection

The ransomware payload is executed through a dropped binary.

- **Process:** tasksche.exe
- **Path:** C:\Windows\

- **Detection Logic**:

  Monitor process creation logs (e.g., Event ID 4688 / Sysmon Event ID 1) for execution of non-standard binaries such as tasksche.exe from system directories. Flag processes

that, mimic legitimate Windows components but are not part of the baseline system behavior, especially when executed with suspicious command arguments.

Example SIEM QUERY (Conceptual):

EventID = 4688 AND

NewProcessName

= "C: \Windows\tasksche.exe".

3. Shadow Copy Deletion (Ransomware Indicator)

WannaCry disables recovery mechanisms by deleting shadow copies to prevent file restoration.

- **Command Indicator:**

  vssadmin delete shadows

Detection Logic:

Monitor processes creation logs (Event ID 4688/Sysmon Event ID 1) for execution of vssadmin.exe with arguments related to shadow copy deletion. Flag executions initiated by non-administrative users or unusual parent processes, as this strongly indicates ransomware activity.

Example SIEM Query (Conceptual):

EventID = 4688 AND

NewProcessName = "C:\Windows\System32\vssadmin.exe"

AND Command Line = "delete *shadows*"

4. Abnormal File Modification Activity

WannaCry encryption generates high-volume file system changes in a short time window.

Indicators:

Rapid files write/modify operations.

File extensions changes (e.g., .WNCRY)

Detection Logic:

Monitor file creation and modification events (Sysmon Event ID 11/15 or EDR telemetry) for abnormal spikes in file activity from a single process. Flag processes that modify a large number of files across multiple directories within a short timeframe, especially when accompanied by extension changes.

Example SIEM Query (Conceptual):
EventID = 11 AND (TargetFilename = "*.WNCRY" OR TargetFilename = ".WNCRYT").

Correlation Logic
Single indicators may generate false positives; however, correlation of multiple behavior significantly increases detection confidence.

A combination of:

- Service creation (mssecsvc2.0).
- Suspicious process execution (tasksche.exe).
- Shadow copy deletion (vssadmin delete shadows).
- Mass file modification.

Within a short timeframe should trigger a **high-severity ransomware alert**.

SOC Analyst Action

- Isolate infected endpoints immediately (EDR containment).
- Block SMB (TCP 445).
- Identify lateral movement scope (scan logs for other infected hosts).
- Initiate incident response and containment procedures.

5. Recommended Detection Queries (Microsoft Sentinel KQL & Splunk)
The following detection queries are based on known WannaCry IOCs and have been developed as part of this threat analysis to demonstrate detection engineering concepts.

Microsoft Sentinel (KQL):

1. Malicious Service Creation – WannaCry Persistence
SecurityEvent

```
| where EventID == 7045
| where ServiceName =~ "mssecsvc2.0"
| project TimeGenerated, Computer, ServiceName, ServiceFilename, Account
```

2. Malicious Process Execution – WannaCry Payload

```
SecurityEvent
| where EventID == 4688
| where NewProcessName has "tasksche.exe"
| project TimeGenerated, Computer, NewProcessName, ParentProcessName, Account
```

3. Shadow Copy Deletion – Ransomware Indicator

```
DeviceProcessEvents
| where ProcessCommandLine has "vssadmin"
| where ProcessCommandLine has "delete shadows"
| project TimeGenerated, DeviceName, ProcessCommandLine, InitiatingProcessFileName
```

4. Encrypted File Detection – .WNCRY Extension

```
DeviceFileEvents | where FileName endswith ".WNCRY" | project TimeGenerated,
DeviceName, FileName, FolderPath, InitiatingProcessFileName
```

Splunk:

```
Index = wineventlog  EventCode = 7045
ServiceName ="mssecsvc2.0"  OR
EventCode = 4688  NewProcessName = "tasksche.exe"
```

5. Correlated WannaCry Activity Detection (High Confidence Alert)

Correlates service creation, process execution, shadow copy deletion, and file encryption activity across multiple log sources to generate a high-confidence WannaCry ransomware alert.

```
let serviceCreation = SecurityEvent
| where EventID == 7045
```

```
| where ServiceName =~ "mssecsvc2.0"
| project Computer, TimeGenerated;

let processExecution = SecurityEvent
| where EventID == 4688
| where NewProcessName has "tasksche.exe"
| project Computer, TimeGenerated;

let shadowDelete = DeviceProcessEvents
| where ProcessCommandLine has "vssadmin delete shadows"
| project DeviceName, TimeGenerated;

let fileActivity = DeviceFileEvents
| where FileName endswith ".WNCRY"
| project DeviceName, TimeGenerated;

serviceCreation
| join kind=inner processExecution on $left.Computer == $right.Computer
| join kind=inner shadowDelete on $left.Computer == $right.DeviceName
| join kind=inner fileActivity on $left.Computer == $right.DeviceName
| where TimeGenerated between (ago(1h) .. now())
| project Computer, TimeGenerated
```

Log Sources: Microsoft Sentinel — SecurityEvent, DeviceProcessEvents, DeviceFileEvents

Detection Logic: Joins four independent indicators within a 1-hour window. A match across all four confirms active WannaCry execution with high confidence, minimizing false positives from single-indicator alerts.

SOC Analyst Action: Immediately isolate the matched endpoint via EDR. Escalate to Incident Response. Block TCP 445 at network perimeter.

7.2. EDR Detection &Endpoint Behavior Analysis:

EDR solutions complement SIEM and network monitoring by detecting ransomware behavior directly on endpoints. SOC analysts leverage EDR telemetry to identify suspicious processes, abnormal file system activity, and lateral movement attempts.

Log Sources / Telemetry Used:

- Endpoint Process Logs (creation, parent-child relationship)
- File System / FIM (File Integrity Monitoring) Logs
- Registry Changes / Persistence Logs
- Network Connections (SMB traffic monitoring)
- Anti-malware / Behavioral Alert Logs

1. Malicious Process Execution Detection

WannaCry executes its ransomware payload through a dropped binary on the endpoint.

Process Indicator: tasksche.exe
Path: C:\Windows\

Detection Logic:

Detect creation of tasksche.exe in C:\Windows\ by svchost.exe or other system processes. This process is known to drop and execute the WannaCry ransomware payload. Monitor for unusual parent-child process relationships and suspicious command-line arguments that are not part of normal Windows behavior.

Example EDR Query / Conceptual:

- **Process Name** = tasksche.exe
- **Path** = C: \Windows\
- **Parent Process** = svchost.exe OR unknown system process.
- **Command-line arguments** = suspicious or not standard.

SOC Analyst Action:

- Immediately locate the affected endpoint.
- Terminate the malicious process if still running.

- Collect forensic logs from the endpoint (process creation, registry, and file system activity) for correlation with SIEM alerts.

2. Shadow Copy & Volume Snapshot Deletion Detection

WannaCry disables Windows recovery by deleting shadow copies, preventing users from restoring encrypted files.

Indicator: Execution of vssadmin delete shadows /all /quiet

Detection logic:

- Monitor vssadmin.exe or wmic.exe commands that attempt to delete shadow copies
- Pay attention to processes running these commands outside normal administrative tasks or triggered by unusual parent processes.
- Unusual timing or frequency (multiple shadow copies deleted in seconds) is a strong ransomware signal.

Example EDR Query / Conceptual:

- **Process Name:** vssadmin.exe.
- **Command Line contains =** delete shadows.
- **Parent Process =** non-standard (not normal admin task).

SOC Analyst Action:

- Immediately isolate the endpoint.
- Stop or block execution of vssadmin.exe commands if possible.
- Check other endpoints for similar activity to detect lateral movement.
- Preserve forensic evidence (event logs, registry, shadow copy metadata) for incident response.

7.3. Network-Based Detection (IDS/IPS & Traffic Analysis)

Network detection focuses on identifying WannaCry aggressive SMB scanning behavior, EternalBlue exploit patterns, and lateral movement across internal network segments.

Key Network Indicators:

- **High Volume SMB Scanning**
  WannaCry scans both local and internet-facing systems for open port 445.
  A single infected host can attempt thousands of SMB connections per minute.

Indicators:

- Abnormal spikes in TCP 445 connection attempts.
- Multiple SYN packets sent to sequential or random IPs.
- Single host connecting to hundreds of IPs within minutes.

- **EternalBlue Exploit Pattern**
  Malformed SMB packets are sent to exploit CVE-2017-0144 on unpatched systems.

Indicators:

- NT Trans request anomalies in SMB traffic.
- IDS signature match: ET EXPLOIT EternalBlue MS17-010.
- Unexpected SMB negotiation sequences.

- **East-West Lateral Movement**
  WannaCry spreads internally between hosts- unusual for normal enterprise traffic.

Indicators:

- Workstation-to-workstation SMB traffic – normally not expected.
- High internal SMB connection volume from a single IP source.
- Rapid sequential scanning of internal subnet.

- **Kill Switch DNS Query**
- Every WannaCry execution attempts to resolve the kill switch domain before encrypting.

Indicators:

- **DNS query to:**

iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com

- Any internal host querying this domain = active WannaCry infection confirmed.

Detection Tool:

- **Wireshark** --- packet capture and SMB traffic analysis.
- **Zeek** --- network flow monitoring.
- **Snort/Suricata** --- IDS signatures for EternalBlue .
- **Microsoft Sentinel** --- network anomaly detection rules.

Example Network Detection Query (Microsoft Sentinel KQL):

```
// Detect high volume SMB connections from single host
NetworkCommunication
| where DestinationPort == 445
| summarize ConnectionCount = count() by SourceIP, bin(TimeGenerated, 1m)
| where ConnectionCount > 100
| project TimeGenerated, SourceIP, ConnectionCount
```

SOC Analyst Action:

- Block TCP 445 at perimeter firewall immediately.
- Identify source IP of scanning activity.
- Isolate affected host from network segment.
- Check DNS logs for kill switch domain query.
- Correlate with SIEM & EDR alerts for full incident scope.

7.4. Indicators of Compromises (IOCs) for WannaCry Ransomware:

This section presents validated Indicators of Compromise (IOCs) associated with the WannaCry ransomware, derived from authoritative sources such as CISA (TA17-132A), threat intelligence reports and malware analysis. These IOCs represent observable artifacts across

host, network, and file-system levels that enable SOC analysts to detect, triage, and respond to active or past infections.

From an analyst perspective, IOCs are used for threat detection, correlation, and incident validation across SIEM, EDR, and Threat intelligence platforms. High-confidence detection is achieved when multiple IOC categories are observed together within a short time window.

- **File Hash Indicators (Static Detection – Malware Identification)**
  File Hashes helps to identify known WannaCry binaries via hash matching.

  Log Sources : EDR, Antivirus, File Integrity Monitoring, SIEM (Threat Intelligence feeds)

  SHA-256 Indicators:
- 24d004a104d4d54034dbcffc2a4b19a11f39008a575aa614ea04703480b1022c → **Dropper.**

- ed97e8e590c7a1c404655a3024859f3e7ef9207085efcf0f015b678c18712f5a → **Encryption module.**

- 84c82835a5d21bcf76663f350c3ac1c0f0e69b59e5553e1a14156631168f0658 → **Ransomware payload.**

  Detection Logic:
  Alert when file hash matches known WannaCry indicators from threat intelligence sources.

  Example:
  Filehash IN (Known_WannaCry_Hashes)

  Risk:
  Confirmed execution of known WannaCry component on endpoint.

  Limitation:

Ineffective against modified variants, packed binaries, or hash changes → requires behavioral detection support.

- **Network-Based Indicators (C2 & Propagation Detection)**

Function:
Detect WannaCry propagation, kill-switch behavior, and external communication

Log Source:
Network IDS/IPS, Firewall logs, DNS logs, NetFlow, SIEM

- **Key Indicators:**

Kill-Switch Domain →
iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea[.]com

TOR C2 (.onion) →
- gx7ekbenv2riucmf[.]onion
- 57g7sp3zpk7ih7ht[.]onion
- xxp75yx7a3qqhbu7[.]onion
- dj7cn6cn8p0p78hj[.]onion

Port / Protocol Activity:
- TCP 445 → SMB exploitation (EternalBlue)
- TCP 139, UDP 137–138 → NetBIOS scanning / lateral movement

Detection Logic:
- Alert on DNS queries to kill-switch domain
- Detect high-volume outbound SMB (TCP 445) connections from a single host
- IDS/IPS signature match for EternalBlue exploit patterns
- Identify abnormal internal east-west SMB traffic

Example (Conceptual):

- DNSQuery == "iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com"
- ConnectionCount(TCP 445) > Threshold per host

Risk:

- Kill-switch query → active WannaCry execution attempt
- High SMB scanning → active worm propagation within network

Limitation:

- Kill-switch domain now sinkholed → may not always indicate active infection
- SMB traffic may generate false positives in large enterprise environments
- Encrypted or proxied traffic can hide TOR communication.

- **Host-Based Indicators (Endpoint Artifacts)**

Function:

Identify WannaCry execution, persistence, and ransomware activity on endpoints

Log Source:

EDR telemetry, Windows Event Logs (4688, 7045), Sysmon (Event ID 1, 11), File Integrity Monitoring

Key Indicators:

Malicious Files:

- C:\Windows\tasksche.exe → ransomware payload execution
- mssecsvc.exe → worm component
- @WanaDecryptor@.exe → ransom UI

Ransom Note:

- !Please Read Me!.txt
- Encrypted File Extensions:
- .WNCRY, .WCRY, .WNCRYT

Detection Logic:

- Alert on execution of tasksche.exe from system directories.
- Detect creation of suspicious service (mssecsvc2.0).
- Identify rapid file modifications with .WNCRY extensions.
- Monitor for ransom note file creation across directories.

Example (Conceptual):

- ProcessName == "tasksche.exe" AND Path == "C:\Windows\".
- FileName endswith ".WNCRY".
- EventID == 7045 AND ServiceName == "mssecsvc2.0".

Risk:

- High-confidence ransomware execution and file encryption activity.
- Active endpoint compromise with persistence.

Limitation:

- File names can be changed in variants.
- Legitimate admin activity may create similar logs (false positives).
- Requires correlation with network and behavioral indicators for confirmation.

- **Persistence & Registry Indicators**

Function: Detect persistence mechanisms and post-exploitation foothold.

Log Source: Windows Event Logs (7045), Sysmon (Registry events), EDR telemetry.

Key Indicators:

Service Creation:

- Service Name: mssecsvc2.0.
- Display Name: Microsoft Security Center (2.0) Service.

Registry Keys:

- HKCU\Software\WanaCrypt0r\

- HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\ → points to tasksche.exe.

Detection Logic:

- Alert on new service creation with name mssecsvc2.0.
- Detect registry Run key modifications pointing to suspicious executables.
- Identify services mimicking legitimate Microsoft naming patterns.

Example (Conceptual) →

- EventID == 7045 AND ServiceName == "mssecsvc2.0".
- RegistryPath contains "CurrentVersion\\Run" AND Value contains "tasksche.exe".

Risk:

- Persistent malware execution across system reboots.
- Strong indicator of post-exploitation foothold.

Limitation:

- Service names can be modified in variants.
- Legitimate software may create similar registry entries → requires correlation.

- **Behavioral Indicators (High-Confidence Detection):**

Function:

Detect ransomware activity based on behavior rather than static indicators.

Log Source: EDR telemetry, Sysmon (Process/File events), SIEM correlation.

Key Indicators:

- **Execution of:** vssadmin delete shadows /all /quiet
- Rapid file encryption across multiple directories.
- Mass file renaming to .WNCRY
- High CPU / disk I/O spikes High-volume SMB scanning (worm propagation)

Detection Logic:

Correlate multiple behaviors within a short time window:

- Suspicious process execution (tasksche.exe).
- Service creation (mssecsvc2.0).
- Shadow copy deletion.
- High-volume file modification.

Example (Conceptual):

- Process == "vssadmin.exe" AND CommandLine contains "delete shadows"
- FileModificationRate > Threshold
- Correlation: 3+ indicators within timeframe → trigger alert

Risk:

- Active ransomware execution with file encryption in progress.
- High-impact compromise affecting availability

Limitation:

- Individual behaviors may generate false positives.
- Requires correlation for high-confidence detection.

- **Exploitation Indicator (Propagation Root Cause):**

Function:

Detect initial exploitation and worm propagation activity.

Log Source: IDS/IPS, Firewall logs, Network telemetry, SIEM.

Key Indicators:

- Continuous scanning on TCP port 445.
- Exploit pattern: malformed SMB packets (EternalBlue / MS17-010).

Detection Logic:

- Alert on IDS signatures matching EternalBlue exploit.
- Detect abnormal SMB traffic volume (east-west movement).
- Identify repeated connection attempts to multiple hosts over port 445.

Example (Conceptual):

- DestinationPort == 445 AND ConnectionCount > Threshold
- IDS Alert == "MS17-010 / EternalBlue".

Risk:

- Active exploitation of SMB vulnerability.
- Ongoing lateral movement and worm propagation.

Limitation:

- High SMB traffic may exist in enterprise environments.
- Requires tuning to avoid false positives.

The following table provides a consolidated IOC quick reference for use in SIEM, EDR, and threat intelligence platforms.

IOC Type	Indicator	Category
SHA-256 Hash	24d004a104d4d54034dbcffc2a4b19a11f39008a575aa614ea04703480b1022c	File Dropper
SHA-256 Hash	ed97e8e590c7a1c404655a3024859f3e7ef9207085efcf0f015b678c18712f5a	File Encryption Module
SHA-256 Hash	84c82835a5d21bcf76663f350c3ac1c0f0e69b59e5553e1a14156631168f0658	File Ransomware Payload
Domain	iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea[.]com	Network Kill Switch
TOR C2	gx7ekbenv2riucmf[.]onion	Network C2
Port	TCP 445	Network SMB Exploitation
Port	TCP 139, UDP 137-138	Network NetBIOS.

File	tasksche.exe	Host Ransomware Binary
File	mssecsvc.exe	Host Worm Component
Service	mssecsvc2.0	Host Persistence
Extension	.WNCRY, .WCRY, .WNCRYT	Host Encrypted Files
Ransom Note	!Please Read Me!.txt	Host Artifact
Registry	HKCU\Software\WanaCrypt0r\	Host Persistence
Bitcoin Wallet	13AM4VW2dhxYgXeQepoHkHSQuy6NgaEb94	Financial Ransom

7.5. YARA-Based Detection

YARA-based detection is used to identify WannaCry ransomware by matching known binary patterns, strings, and behavioral artifacts within files and memory. Unlike hash-based detection, YARA can detect variants that reuse internal code patterns even when file hashes change.

Function:

Detect WannaCry malware using signature-based pattern matching across files and memory.

Log Sources: EDR platforms, Malware Sandbox, Threat Hunting tools, Memory analysis tools.

- **Key Detection Artifacts:**

Embedded Strings:

- WannaDecryptor
- WNCRY

- Wcry@123

Mutex Indicators:

- Global\MsWinZonesCacheCounterMutexA.

File Artifacts:

- tasksche.exe
- Mssecsvc.exe

Behavioral Strings:

- Vssadmin delete shadows
- Icacls ./grant Everyone:F

Detection Logic:

YARA rule detect WannaCry by matching a combination of:

- Known ransomware-related strings
- Internal execution artifacts
- Unique mutex Identifiers

Detection is triggered when multiple indicators are found within a binary or memory region.

Example (Simplified YARA Rule):

```
rule WannaCry_Ransomware_Simple
{
  strings:
    $s1 = "WannaDecryptor"
    $s2 = "WNCRY"
    $s3 = "mssecsvc.exe"
    $s4 = "tasksche.exe"
    $s5 = "Wcry@123"

  condition:
    2 of ($s*)
}
```

Risk:

Indicates the presence of WannaCry ransomware components on disk or in memory, even if file names or hashes are modified.

Limitation:

- Can be bypassed using packing, encryption, or code obfuscation.
- May generate false positives if strings appear in benign files.
- Requires continuous rule updates for new variants.
- Not sufficient alone must be correlated with behavioral and network indicators.

---

8. INCIDENT RESPONSE & IMMEDIATE MITIGATION

WannaCry is a fast-spreading worm-based ransomware, so response actions must prioritize speed, containment, and coordination. Once indicators of compromise are detected, the objective is to immediately isolate affected systems, stop further propagation, and prevent ongoing encryption activity. Here, I am going to outline the incident response actions a SOC analyst should execute to contain the threat, identify affected assets, and initiate recovery procedures while preserving forensic evidence.

These steps follow a standard incident response lifecycle, starting with immediate containment, followed by eradication, investigation, and recovery.

8.1. Containment

8.1.1. Endpoint Containment

Action:

- Immediately isolate the infected endpoint using EDR containment
- Disconnect the system from network (LAN / Wi-Fi) if isolation is not available
- Disable shared drives and restrict remote access.

Purpose: Prevent further ransomware execution and stop lateral movement across the network.

8.1.2. Network Containment

Action:

- Block TCP ports 445, 139, and UDP ports 137-138 at firewall level.
- Identify and isolate systems generating high-volume SMB traffic.
- Restrict internal SMB communication where not required.

Purpose: Stop worm propagation and prevent lateral movement across network segments.

8.2. Eradication

8.2.1. Process & Service Termination

Action:

- Terminate malicious process (tasksche.exe).
- Stop and remove malicious service (mssecsvc2.0).
- Block execution of suspicious binaries via EDR.

Purpose: Stop active ransomware execution and remove persistence mechanisms.

8.2.2. Vulnerability Remediation

Action:

- Apply MS17-010 patch on all systems
- Disable SMBv1 where not required
- Scan network for unpatched or vulnerable hosts

Purpose: Eliminate exploitation vector and prevent reinfection

8.3. Detection & Impact Analysis

8.3.1 Identify Infection Scope

Action:

- Query SIEM for:
- SMB scanning activity

- vssadmin delete shadows execution
- .WNCRY file creation
- Identify all affected endpoints and user accounts

Purpose: Determine spread and impact across the environment

8.4. Recovery

8.4.1. Ransom Payment Decision Guidance

- Ransom Payment is strongly discouraged by agencies like Federal Bureau of Investigation, Cybersecurity and Infrastructure Security Agency and National Cyber Security Center.
- No guarantee of decryption; may fund criminal operations.
- Potential legal risk if a threat actor is sanctioned.
- In WannaCry, Payment rarely resulted in recovery due to flawed payment tracking.

8.4.2. Backup Validation & Recovery

Action:

- Restore affected systems from clean offline backups
- Verify backup integrity before restoration
- Ensure backups are not connected to infected network

Purpose: Recover encrypted data safely without reinfection.

8.5. Investigation

8.5.1. Forensic Evidence Preservation

Action:

- Collect logs from SIEM, EDR, Sysmon, and firewall
- Preserve disk and memory images if required
- Maintain chain of custody for investigation

Purpose: Support incident investigation and root cause analysis.

8.6. Communication & Coordination

8.6.1. Communication & Awareness

Action:

- Notify security, IT, and management teams
- Inform users to avoid suspicious files, links, or attachments
- Coordinate response across teams

Purpose: Ensure controlled response and prevent further spread.

8.7. Post-Incident Review & Lessons Learned

8.7.1. Lessons Learned & Security Improvement

Action:

- Conduct root cause analysis.
- Identify detection and control gaps.
- Update SIEM rules, EDR policies, and patching strategy.

Purpose: Strengthen security posture and prevent recurrence

---

9. IDEAL PREVENTION ARCHITECTURE

Building a defense against WannaCry-style attacks is not just about applying one patch or disabling one protocol – it requires thinking in layers. In this section, I want to suggest an ideal security architecture that enterprises can implement to protect themselves from

ransomware and worm-based attacks like WannaCry. Each layer addresses a specific point in the attack chain, so even if one layer fails, the next one catches it.

Layered Security Architecture Overview:

Layer	*Control*	*Purpose*
Layer 1	**Perimeter Firewall**	**Block TCP 139, 445, UDP 137-138 externally.**
Layer 2	**IDS/IPS**	**Detect EternalBlue exploit signatures.**
Layer 3	**Network Segmentation**	**Prevent lateral movement between zones**
Layer 4	**Endpoint EDR**	**Detect malicious processes and file changes**
Layer 5	**SIEM Monitoring**	**Correlate alerts across all layers.**
Layer 6	**Backup System**	**3-2-1 rule, offline immutable backups**

Detailed Implementation Steps:

9.1. Apply MS17-010 Patch

All Windows systems must have the MS17-010 update installed. This patch fixes the SMBv1 vulnerability exploited by WannaCry. Systems that cannot be patched immediately should be isolated from the network until updates are applied. Emergency patches are also available for unsupported systems like Windows XP, Server 2003, and Windows 8.

9.2. Disable SMBv1

SMBv1 is outdated and insecure. Disabling it helps stop ransomware propagation:

- **Clients (Windows 8.1 / later)**: Control Panel → Programs → Turn Windows features on/off → Uncheck SMB 1.0/CIFS → Restart.

- **Servers (Windows Server 2012 R2 / later):** Server Manager → Manage → Remove Roles and Features → Uncheck SMB 1.0/CIFS → Restart.

This reduces exposure even if a patch cannot be applied immediately.

9.3. Block SMB Ports Externally

Ransomware spreads through exposed SMB ports. Network devices should block TCP 139, TCP 445, UDP 137, and UDP 138 at the perimeter firewall. SMB should never be exposed to the internet.

9.4. IDS/IPS Deployment

Deploy intrusion detection and prevention systems to monitor for EternalBlue exploit signatures and abnormal SMB traffic patterns. IDS/IPS acts as an early warning layer before ransomware reaches endpoints.

9.5. Endpoint Protection (EDR/Antivirus)

Install and maintain endpoint detection and response (EDR) or advanced antivirus solutions. These tools can detect suspicious processes, unusual file system changes, and attempts to delete shadow copies. Infected endpoints should be isolated immediately upon alert.

9.6. Backup Strategy

Frequent backups are essential for recovery:

- Follow the 3-2-1 rule: three copies of data, on two types of media, with one offline.
- Store backups offline or in immutable cloud storage to prevent ransomware from encrypting them.
- Test backups regularly to ensure successful restoration.

9.7. Network Segmentation

Divide the network into smaller segments with access controls. This limits lateral movement of malware and isolates critical systems. Firewall rules should enforce separation between different network zones – If one segment gets infected, others remain protected.

9.8. SIEM Monitoring

Centralized SIEM monitoring correlates alerts from all layers — firewall, IDS, EDR, and endpoint logs — into a single view. This allows SOC analysts to detect multi-stage attacks early and respond before encryption begins.

9.9. User Access and Least Privilege

Restrict user privileges to the minimum needed for daily tasks. Admin rights should be limited, preventing ransomware from performing high-impact actions like deleting backups or modifying system files.

9.10. Application Control / Whitelisting

Only allow approved applications to access sensitive data. Tools like AppLocker can prevent unauthorized executables from running, stopping ransomware from encrypting files.

9.11. Security Awareness

Educate employees about phishing emails, malicious attachments, and suspicious macros in Office documents. Users should never enable macros in documents from untrusted sources.

9.12. Additional Measures:

- Block Tor traffic and connections to known malicious nodes.
- Keep all systems and software updated.
- Use multi-factor authentication for critical accounts.
- Maintain an up-to-date asset inventory and run continuous vulnerability scanning to identify unpatched or legacy systems before attackers do.

Key Insights: These layers work together — patching removes the vulnerability; segmentation limits the spread, EDR catches execution, SIEM correlates everything, and backups ensure recovery. No single control is enough on its own. Defense in depth is the only reliable strategy against fast-spreading worm-based ransomware.

---

10. MITRE ATT&CK MAPPING & DETECTION INSIGHTS

This section maps WannaCry (S0366) behaviors to the MITRE ATT&CK framework, focusing on confirmed techniques observed during the attack. Its correlating adversary TTPs with real-world telemetry detection opportunities, and defensive controls, providing both SOC-level detection mapping and CTI-driven analysis of how the attack achieved rapid propagation and impact.

10.1. Attack Mapping to MITRE ATT&CK

The following table maps confirmed WannaCry attack behaviors to the MITRE ATT&CK framework, aligned with the actual attack lifecycle. Only high-confidence techniques observed during the attack are included to ensure accuracy and relevance for SOC detection and CTI analysis.

Stage	Technique ID	Technique Name	WannaCry Implementation
Initial Access	T1210	Exploitation of Remote Services	SMBv1 exploit (EternalBlue)
Execution	T1059	Command Execution	Tasksche.exe execution
Persistence	T1543.003	Windows Service Creation	mssecsvc2.0
Defense Evasion	T1564	Hide Artifacts	Attrib +h
Defense Evasion	T1222	Permission Modification	icacls
Discovery	T1016 / T1018	Network Discovery	Subnet + host scanning

Lateral Movement	T1021.002	SMB / Admin Shares	Internal propagation
Lateral Movement	T1570	Lateral Tool Transfer	Payload copy to hosts
Command & Control	T1090.003	Proxy	.onion communication
Impact	T1486	Data Encrypted for Impact	File encryption (.WNCRY)
Impact	T1490	Inhibit Recovery	Vssadmin delete shadows
Impact	T1489	Service Stop	Kill database services

10.2. Detection Coverage Mapping

This section maps WannaCry ATT&CK techniques to corresponding log sources and detection methods, highlighting how each stage of the attack can be identified within a SOC environment.

Technique ID	Technique Name	Log Source	Detection Method
T1210	Exploitation of Remote Service	Firewall / IDS	SMB exploit signatures
T1059	Command Execution	Event ID 4688 / Sysmon	Tasksche.exe execution
T1543.003	Service Creation	Event ID 7045	Suspicious service installation
T1490	Inhibit Recovery	Sysmon / EDR	vssadmin delete shadows

T1486	Data Encrypted for Impact	File Monitoring	Mass file changes (.WNCRY)
T1021.002	SMB lateral Movement	Network logs	East-West SMB traffic anomaly
T1018	Remote Discovery	Network Telemetry	Sequential IP scanning

10.3.MITRE ATT&CK Technique Deep Dive and CTI Analysis

This section provides a focused deep-dive into the most critical MITRE ATT&CK techniques leveraged by WannaCry. Only high-impact and operationally relevant techniques are analyzed to extract detection and defense intelligence.

- **T1210 – Exploitation of Remote Services (SMB)**

Exploit vulnerable remote services to achieve unauthenticated remote code execution and enable lateral movement.

WannaCry Implementation:
Uses EternalBlue (MS17-010) to send crafted SMBv1 packets over TCP port 445, triggering buffer overflow and executing malicious payload on remote systems without authentication.

CTI Insight:
Relies on widespread presence of unpatched SMBv1 services. Legacy protocol exposure + missing patch management created a wormable attack surface enabling rapid autonomous propagation across internal networks.

Detection Opportunity:

- Detection of abnormal SMB traffic spikes on port 445.
- IDS/IPS signatures for EternalBlue exploit patterns.
- SMB service crashes or abnormal restarts post network access.
- Suspicious child processes spawned from SMB service context.

Defensive Control:

- Apply MS17-010 patch across all systems.
- Disable SMBv1 protocol.
- Restrict/monitor TCP 445 via internal segmentation.
- Deploy exploit protection (e.g., Defender Exploit Guard).
- Continuous vulnerability scanning for exposed services.

- **T1486 – Data Encrypted for Impact**

Adversaries encrypt data on target systems or networks to deny access and disrupt availability. Encryption may target user files, system files, disk partitions, virtual machines, or cloud storage objects. The goal can be ransom (monetary extortion) or permanent denial of access.

WannaCry Implementation:

WannaCry encrypts user files and critical system files using symmetric encryption (AES) and demands Bitcoin ransom for decryption. It specifically targets common file types (Office documents, PDFs, images) and spreads autonomously via SMBv1 (EternalBlue) to maximize impact across networks.

CTI Insight:

Relies on unpatched Windows systems and SMB exposure. Encryption combined with worm-like propagation enabled rapid organization-wide disruption. Legacy systems and poor backup hygiene amplified operational impact.

Detection Opportunity:

High-frequency file modifications with unusual extensions (e.g., .wncry).
Multiple simultaneous shadow copy deletions or registry tampering.
Abnormal process creation from SMB service context or lateral movement tools.
Creation of ransom notes in directories correlating with encrypted files.

Defensive Control:

Apply MS17-010 patch and disable SMBv1.
Implement offline and versioned backups; verify integrity regularly.

Use endpoint protection with Ransomware Behavior Prevention / ASR rules.
Monitor file-system events for rapid, unusual encryption activity.
Restrict network exposure of critical systems and segment high-value data.
Leverage cloud storage IAM policies and SSE controls to prevent unauthorized encryption.

- **T1543.003 - Create / Modify Service**

Adversaries create or modify Windows services to achieve persistence or privilege escalation. Services are background programs that start with Windows and have SYSTEM-level execution privileges. Modifications may involve new services, altering existing services, or installing malicious drivers, often via system utilities (sc.exe, PnPUtil.exe), API calls (CreateServiceW(), ZwLoadDriver()), or Registry edits. Malicious services may masquerade as legitimate ones or be hidden using SDDL to evade detection.

WannaCry Implementation:
WannaCry installs the service mssecsvc2.0 with the display name "Microsoft Security Center (2.0) Service" to ensure persistence after reboot. This service allows the ransomware to maintain execution context and propagate across networks without user interaction.

CTI Insight:
Persistence via services allows execution under SYSTEM privileges, bypassing normal user restrictions. Adversaries may exploit this to escalate privileges, deploy signed or vulnerable drivers (BYOVD), and hide artifacts. Malicious services often use names mimicking legitimate Windows components to evade detection.

Detection Opportunity:

- Creation or modification of services with unusual or rare names under HKLM\SYSTEM\CurrentControlSet\Services.
- Use of command-line utilities (sc.exe, powershell.exe) or API calls (CreateServiceW) for service registration.
- Services executing unsigned binaries or binaries in non-standard directories.

- Parent-child process anomalies, e.g., services spawned from non-standard executables.
- Sudden system reboots or driver installations correlating with new service creation.

Defensive Control:

- Enable MS Defender Attack Surface Reduction (ASR) rules and Vulnerable Driver Blocklist.
- Enforce Driver Signature Enforcement and restrict unsigned service execution.
- Audit service creation/modification events using Windows Event Logs and SIEM correlation.
- Limit administrative privileges; restrict which users or groups can manage services.
- Monitor and alert on unusual service names, execution paths, and Registry changes.

- **T1490 – Inhibit System Recovery**

Adversaries disable or delete system recovery features to prevent restoration of data and system functionality. This can include deleting Volume Shadow Copies, backup catalogs, VM snapshots, or disabling recovery environments on endpoints, servers, network devices, or cloud platforms. The goal is to augment the impact of data destruction or ransomware operations, making recovery difficult or impossible.

WannaCry Implementation:

WannaCry deletes all VSS shadow copies using vssadmin.exe, disables recovery features via bcdedit.exe, removes backup catalogs with wbadmin.exe, and can manipulate system recovery using REAgentC.exe and wmic.exe. These actions prevent victims from restoring encrypted files, maximizing operational disruption.

CTI Insight:

Relies on default system utilities and elevated privileges. Attackers often combine shadow copy deletion with ransomware (T1486) to amplify impact. Systems with local backups or improperly isolated snapshots are particularly vulnerable. Attack effectiveness increases on legacy Windows systems or poorly segmented networks.

Detection Opportunity:
Execution of native utilities with destructive arguments: vssadmin delete shadows /all /quiet, wbadmin delete catalog -quiet, bcdedit /set {default} recoveryenabled no, REAgentC /disable, diskshadow delete shadows all.
Unexpected deletion of restore points, VSS snapshots, or VM snapshots.
Changes to WinRE configuration or registry keys related to recovery.
Cloud API calls deleting snapshots, backups, or disabling versioning.

Defensive Control:
Maintain offline, immutable, or versioned backups; regularly verify integrity.
Enable and enforce WinRE (reagentc /enable) and protect recovery-related files/folders with strict ACLs.
Restrict access to backup and recovery utilities using AppLocker, Defender Application Control, or equivalent.
Implement monitoring and alerts for shadow copy deletions, backup catalog modifications, or critical recovery service stoppages.
In cloud environments, enforce IAM policies and service control restrictions to prevent deletion of snapshots or backups.

- ## T1570 – Lateral Tool Transfer

Adversaries move tools or other files between systems within a compromised environment to support lateral movement, staging, or follow-on operations. File transfers may occur over SMB/Admin shares, RDP, native OS tools (scp, rsync, ftp, curl, sftp), or cloud-synced storage (OneDrive, Dropbox). The goal is to deploy malicious tools, execute payloads, or prepare for additional exploitation across multiple hosts.

WannaCry Implementation:
After exploiting SMBv1 via EternalBlue, WannaCry copies its payload to remote systems to propagate across the network. It stages its ransomware binary into accessible shares to execute on newly compromised hosts, enabling rapid lateral spread and maximized impact.

CTI Insight:
Relies on accessible internal shares, weak credentials, or unsegmented networks. Attackers often combine tool transfer with remote execution techniques (e.g., PsExec, WMI) to automate lateral movement. Legacy Windows systems and exposed administrative shares amplify the attack surface.

Detection Opportunity:
Unusual file creation or modification events on network shares (SMB/Admin$) outside normal administrative patterns.
Process execution from unexpected contexts (e.g., cmd.exe, powershell.exe, certutil.exe) correlated with network file writes.
Uncommon use of scp, rsync, ftp, curl, sftp, or cloud sync apps transferring executables between internal systems.
VM/datastore file uploads (VMDK/VMX) followed by immediate execution or configuration changes.

Defensive Control:
Restrict and segment network shares; enforce least privilege on Admin$ and other high-value shares.
Monitor and alert on anomalous lateral file movements and process executions.
Use host-based firewall rules to block unauthorized SMB, FTP, and RDP transfers.
Enforce application control (AppLocker/Defender) to prevent execution of newly transferred binaries.
Leverage network IPS/IDS to detect signature-based or anomalous file transfer activity.
Harden cloud storage permissions and disable automatic sync for critical directories.

- **T1573.002 - Encrypted Channel : Asymmetric Cryptography**

Adversaries use asymmetric (public key) cryptography to encrypt command and control (C2) traffic. Data is encrypted with the receiver's public key and can only be decrypted by the

receiver's private key. Common algorithms include RSA and ElGamal. Often used to secure C2 channels over protocols like TLS/SSL or Tor.

WannaCry Implementation:
WannaCry used Tor to route its custom C2 traffic. While not encrypting all communications with asymmetric cryptography, it relied on asymmetric cryptography principles to protect key exchange for its control communications over anonymized channels.

CTI Insight:
Asymmetric encryption in C2 traffic prevents interception and tampering. Threat actors often combine it with TLS/SSL or anonymizing networks to evade detection. Detection is difficult due to legitimate enterprise crypto use; unusual implementations or endpoints are strong indicators.

Detection Opportunity:

- Processes loading asymmetric crypto libraries (e.g., rsaenh.dll, crypt32.dll) and initiating outbound connections.
- Abnormal certificate chains, malformed handshakes, or SSL/TLS sessions on non-standard ports.
- Dynamic linking of libcrypto/libssl from scripts or binaries not normally associated with encryption.
- Unexpected asymmetric crypto sessions in VMware, ESXi, or cloud services outside baseline behavior.

Defensive Control:

- Enable SSL/TLS inspection to analyze encrypted sessions.
- Monitor process creation and module loads for unusual asymmetric crypto usage.
- Baseline TLS/SSL handshakes for critical systems and flag deviations.
- Restrict network egress to approved endpoints and ports.
- Correlate asymmetric crypto usage in SIEM for early detection.

10.4. Defense Mapping – WannaCry

ATT&CK Technique	Function / Risk	Recommended Defense Layer	Implementation
T1543/T1543.003 - Service Creation (mssecsvc2.0)	Persistence → malware maintains access	EDR monitoring, application whitelisting, least privilege	Detect unauthorized service creation; block execution of unknown binaries
T1486 – Data Encryption / Impact	Data loss, operational disruption	Offline & immutable backups, network segmentation	Ensure 3-2-1 backup strategy; restrict lateral movement to contain impact
T1573 / T1573.002 – C2 over Tor	Data exfiltration / control	Firewall rules, network monitoring, SIEM alerts, block TOR nodes	Detect unusual outbound traffic, isolate infected endpoints
T1210 – SMB Exploit	Lateral movement via unpatched SMBv1	Patch management (MS17-010), disable SMBv1, block SMB ports externally	Prevent initial propagation to vulnerable hosts
T1083 – File Discovery	Information gathering	EDR / file activity monitoring, audit logs	Alert on suspicious bulk file access patterns
T1222 / T1222.001 – File Permission Changes	Persistence & obfuscation	Application control, Group Policy, ACL monitoring	Prevent unauthorized file attribute changes (attrib +h, icacls)
T1564 / T1564.001 - Hidden Files	Obfuscation	EDR monitoring, integrity checks	Detect hidden / renamed malware files
T1490 / T1047 – Disable OS Recovery	Prevent recovery	Immutable backups, shadow copy protection, SIEM alerting	Monitor deletion of shadow copies or VSS operations

T1570 / T1570.001 – Remote Copy / Lateral Spread	Propagation	Internal segmentation, EDR process isolation	Limit spread across network segments
T1018 / T1016 – Network Discovery	Recon → pre-attack	SIEM correlation, network scanning detection	Alert on unusual network scanning activity
T1489 – Kill Processes	Disrupt services / cover tracks	EDR, least privilege	Prevent malware from terminating critical services like SQL or Exchange

Layered Defense Summary:

1. **Perimeter / Network:** Firewall, block SMB/TOR, segment network.
2. **Endpoint:** EDR, Process monitoring, application whitelisting.
3. **System Hardening:** Patch management, disable SMBv1, least privilege.
4. **Data Protection:** 3-2-1 backups, shadow copy protection, immutable storage.
5. **Detection / Monitoring:** SIEM alerts, correlation rules, network traffic analysis.
6. **Recovery & Containment:** Endpoint isolation, restoration from backups, escalation workflow.

10.5. CTI Insights

WannaCry (2017) demonstrates a high-impact ransomware campaign leveraging SMBv1 vulnerabilities for rapid propagation. CTI analysis highlights the following TTPs, attack patterns, and operational insights relevant for SOC-level monitoring and threat intelligence.

Observation / TTP	Technical Detail	Enterprise Risk	Detection / SOC Signal	Defensive Insight
SMBv1 Exploitation (T1210)	Uses EternalBlue exploit to propagate laterally via TCP 445 and TCP 139. Targets	Rapid network-wide compromise;	Spike in SMB connections, abnormal SMB session creation,	Apply MS17-010 patch, block SMB externally, network segmentation,

	unpatched Windows systems (MS17-010).	high lateral movement risk.	repeated failed authentication attempts.	monitor SMB traffic anomalies.
Persistence via Service Creation (T1543.003)	Creates service mssecsvc2.0 ("Microsoft Security Center 2.0").	Allows continued execution after reboot.	Detection of new services outside baseline inventory, anomalous service names.	Endpoint monitoring for unknown service creation; alert on deviations.
File Encryption & Data Impact (T1486)	Encrypts user files (.docx, .xlsx, .pdf, images, archives) using AES/RSA.	Denial of access to critical data; potential operational disruption.	Mass file modification alerts, unusual file extension changes, EDR ransomware signature detection.	Maintain offline/immutable backups; EDR with file behavior analytics.
Shadow Copy Deletion (T1490, T1047)	Uses vssadmin.exe, wmic, bcdedit to delete shadow copies.	Prevents easy recovery from backups; increases ransom leverage.	Shadow copy deletion alerts, system restore points removed.	Restrict execution of these tools via AppLocker/Group Policy; monitor vssadmin and wmic usage.
File Attribute Manipulation (T1222.001, T1564.001)	Hides malicious files using attrib +h; sets full access via icacls.	Reduces visibility to users and traditional antivirus.	Sudden change in file attributes; abnormal permissions on sensitive folders.	EDR monitoring for hidden files and abnormal ACL changes; alert on system-wide changes.
Lateral Movement / Remote Copy (T1570, T1018, T1563.002)	Scans local network, enumerates RDP sessions, copies malware to new hosts.	Propagates rapidly in enterprise networks; compromises segmented environments if misconfigured.	Unusual RDP connections, new file creation on remote shares, network scanning patterns.	Segment network zones, monitor RDP usage, restrict lateral SMB access.
Command & Control via Tor (T1573.002, T1090.003)	Uses Tor to communicate with C2 servers, hiding traffic.	Evades traditional network monitoring; delays detection.	Outbound Tor traffic; unknown encrypted connections;	Block Tor at network perimeter, monitor endpoint network

			uncommon DNS resolutions.	anomalies, correlate with known malicious nodes.
Service / Process Targeting (T1489)	Attempts to stop processes for Exchange, SQL Server, MySQL to encrypt databases.	Disrupts critical services and enterprise applications.	Unplanned service termination, EDR alerts on service kill events.	Monitor critical service uptime; alert on unexpected terminations; privilege restrictions on critical service accounts.
Drive / Peripheral Targeting (T1120)	Scans attached drives and network shares, encrypts accessible volumes.	Expands attack surface; impacts removable media and file servers.	Unusual I/O activity on multiple volumes, new file patterns outside baseline.	Restrict auto-mounting of external drives; monitor file access patterns via EDR/SIEM.

Key CTI Takeaways:

- **Attack Speed & Propagation:**
  WannaCry exploited unpatched SMBv1 systems, moving laterally in minutes. Enterprise patching and segmentation are critical to prevent similar rapid outbreaks.
- **Endpoint Indicators:**
  Service creation (`mssecsvc2.0`), hidden file attributes, shadow copy deletion, and ransomware file extensions are high-confidence detection signals for EDR correlation.
- **Network Anomalies:**
  Sudden SMB traffic spikes, RDP enumeration, and Tor-based C2 traffic are strong indicators of compromise at the enterprise network layer.
- **Mitigation Alignment:**
  Preventive controls (MS17-010, SMB blocking, segmentation, AppLocker) directly reduce attack surface, while EDR monitoring and SIEM correlation improve early detection.

- **Operational Insight for SOC Analysts:**
  Analysts should correlate endpoint behavior (hidden files, unusual service creation) with network telemetry (SMB scans, RDP anomalies) and known IOCs to validate alerts, enabling rapid containment before encryption propagates.

---

11. KEY LEARNINGS

This section helps to summarize the most important lessons or takeaways from analyzing the WannaCry attack. These are the lessons that every cybersecurity analyst and researcher should learn from and try to implement these lessons in real-life scenarios.

11.1. Technical Learnings

1. Patches matter more than anything else.

Microsoft released MS17-010 on 14 March 2017. WannaCry started on 12 May 2017. Organizations had 59 days to patch. Most companies including multinational companies like Renault, Nissan, Telefónica and more did not patch systems. That resulted in **$4 billion** in damages. If you take one thing from this report: patch management saves lives and money.

2. Old protocols are dangerous.

SMBv1 was released in 1996. It was outdated, insecure, and should have been disabled years before 2017. WannaCry succeeded because organizations kept old protocols running "just in case." Disable what you don't need. If you take one thing from this report: organizations tend to focus on different aspects of security but often forget the basic and most important patching systems, disabling or discarding outdated software versions or hardware components.

3. Worms spread differently than other malware.

Most malware needs a user to click on something. WannaCry did not. Once inside a network, it moved automatically. This means your defenses must work at the network level, not just the endpoint level. Segmentation and SMB blocking are not optional. If you take one thing from this section, it should be the importance of network level security. It helps us to understand that network segmentation and segregation are not optional but a necessity.

4. Kill switches are not a defense strategy

WannaCry had a kill switch domain. When researchers registered it, the spread slowed. But relying on a kill switch is like hoping the attacker made a mistake. Some did. Most will not. Build your own kill switch through detection and response. From this kill switch section, you should focus on understanding mechanism of attack instead of panicking. Deeply understand malware mechanisms and try to find weakness in them, because most attacks do have small mistakes that can lead to halting of attacks.

11.2. Detection Learnings

5. Single indicators are not enough

A service creation alert (Event ID 7045) could be legitimate. A shadow copy deletion could be an admin. But service creation + shadow copy deletion + file encryption = ransomware. Always correlate multiple signals before confirming an incident. It helps to understand why pattern recognition and correlation are important, it helps to reduce false positive and reduce random time waste on irrelevant event investigation instead of that to focus on real ongoing attacks and to stop their spread in early phase to reduce further losses.

6. Know what normal looks like

You cannot detect abnormal SMB traffic if you do not know your baseline. How many port 445 connections does a typical workstation make? How many shadow copy deletions happen per week? Document your environment's normal behavior. This emphasizes creating and understanding baseline activity to differentiate between normal and abnormal activity to help analysts detect unusual behaviors and respond to them.

7. DNS logs are underrated

The kill switch domain query was clear indicator. Any internal host querying iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com was infected. DNS logs are often ignored. Do not ignore them.

8. EDR & SIEM work together

EDR catches the endpoint behavior (tasksche.exe running). SIEM correlates across systems (which other hosts also show this?). Neither is enough alone. Learning both is mandatory.

11.3. Incident Response Learnings

9. Speed is everything with worms

WannaCry infected 300,000+ systems in hours. Our response must be measured in minutes, not days. Pre-built containment playbooks. Know exactly what to block (TCP 445) and what to isolate before an incident happens. Here, it helps us to understand and emphasize on early detection and response to attacks, especially worm attacks, which needs early detection, and their mitigation to reduce global spread and losses.

10. Isolation first, investigation second

When you see encryption activity, do not wait. Isolate the endpoint immediately. You can investigate later. Every second you wait, the worm spreads to three more systems.

11. Backups are your last line of defense

Organizations with offline, tested backups recovered. Organizations without backups paid ransom or lost data permanently. The 3-2-1 rule is not optional. Verify your backups to work before you need them. WannaCry helps us to realize that how important is it to maintain backups that is a baseline security practice in the CIA triad.

11.4. Threat intelligence Learnings

12. Attribution requires evidence, not just names

Many reports say, "Lazarus Group did it". A CTI analyst asks: "what evidence? Code reuse? Infrastructure overlaps? Timing patterns? Always ask for the proof behind the claim.

13. Understand the difference between vulnerability, exploit, and attack chain.

WannaCry teaches this clearly. The vulnerability was CVE-2017-0144 (SMBv1 flaw). The exploit was EternalBlue (how to trigger it). The attack chain was the full sequence from scanning to encryption. You cannot defend any single piece alone.

14. Public leaks change the threat landscape.

The Shadow Brokers leaked EternalBlue on 14 April 2017. WannaCry appeared on 12 May 2017. When government-grade tools become public, the risk level changes overnight. Monitor leak disclosures as part of threat intelligence.

11.5. Recommendations for Security Teams

Based on this analysis, organizations should prioritize the following actions:

Priority	Action	Why
Critical	Apply MS17-010 patch on all Windows systems	Removes the exploited vulnerability
Critical	Disable SMBv1 across the environment.	Eliminates the attack vector
High	Block TCP 445 at perimeter firewall	Prevents external exploitation
High	Implement network segmentation	Limits lateral movement
Medium	Deploy EDR with behavioral detection	Catches encryption activity
Medium	Maintain offline, tested backups	Enables recovery without ransom

Final Thought from This Analysis:

WannaCry was not sophisticated. It used a patch two months earlier and an exploit that was publicly leaked. It succeeded because organizations failed at basics: patching, disabling old protocols, and network segmentation. As an entry-level analyst, your job is not to stop zero-days. Your job is to get the fundamentals right. WannaCry proves that fundamentals are enough — if you actually do them.

---

12. INTELLIGENCE ASSESSMENT

Prepared by: *Shreyank Upadhyay, Independent Security Researcher*

- **Threat Actor:** Lazarus Group (APT38 subset, assessed with moderate confidence)
- **Suspected Nexus:** Democratic People's Republic of Korea (DPRK, assessed with moderate confidence)
- **Attribution Confidence:** Moderate-High — based on multi-vendor consensus (Microsoft, NSA, GCHQ, US DoJ formal indictment 2018)

Campaign Assessment:

Factor	Assessment
Primary Motivation	**Financial** — sanctions evasion, cryptocurrency generation.
Attack Sophistication	**Medium** — reused NSA-developed tooling, no custom zero-days.
Operational Security	**Low** — kill switch error suggests rushed deployment.
Financial Success	**Low** — ~$130,000 collected vs $4-5B in damage caused.
Strategic Impact	**High** — demonstrated nation-state willingness to deploy destructive worms.

Key Intelligence Judgments:

The disproportionate ratio of damage ($4-5B) to financial gain ($130,000) suggests that the primary objective may not have been purely financial. Analyst assessment with moderate confidence: WannaCry was either a financially motivated operation executed poorly, or a dual-purpose campaign designed to cause disruption while maintaining plausible deniability through ransomware framing.

The kill switch domain — an unregistered random string hardcoded into the binary — is assessed with high confidence as a development artifact or anti-sandbox measure rather than an intentional off switch. Its presence suggests that the malware was deployed before full quality assurance was complete.

Future Threat Relevance:
EternalBlue-based exploitation remains a persistent threat vector. Multiple subsequent campaigns — including **NotPetya (2017)** and **BadRabbit (2017)** — reused the same infrastructure. Legacy systems exposed on SMB ports remain vulnerable in healthcare, manufacturing, and critical infrastructure sectors globally.

Analyst Confidence: High for technical analysis. Moderate for attribution. Low for intent assessment.

Note: Attribution claims in this report rely on published analysis from Microsoft, NSA, GCHQ, and US DoJ. No independent attribution analysis was performed by this author.

---

13. REFERENCES

This report was prepared for educational and portfolio purposes. All sources are listed below. Detection queries, correlation logic, and SOC procedures were independently developed and validated by the author. AI tools (ChatGPT, Claude, DeepSeek) were used only for

formatting, grammar review, and minor editorial assistance; all technical analysis, threat intelligence assessment, and conclusions were performed solely by the author.

1. Microsoft Security Blog

- https://www.microsoft.com/en-us/security/blog/2017/05/12/wannacrypt-ransomware-worm-targets-out-of-date-systems/

Used for: Overview, attack execution (Section 1, Section 3)

2. Microsoft Security Bulletin MS17-010

- https://docs.microsoft.com/en-us/security-updates/SecurityBulletins/2017/ms17-010

- https://www.microsoft.com/en-us/industry/blog/healthcare/2017/06/06/wannacry-ransomware-attack-lessons-learned/

Used for: Vulnerability details, patch information, affected software (Section 4) , Lesson learned (Section 11).

3. NVD (National Vulnerability Database)

- https://nvd.nist.gov/vuln/detail/CVE-2017-0144

Used for: CVSS score 9.3 for CVE-2017-0144 (Section 4)

4. IEEE Xplore (Academic Paper)

- https://ieeexplore.ieee.org/document/8323680

Used for: Static analysis, reverse engineering details, attack chain decomposition (deployment, installation, destruction, command-and-control) - (Section 3, Section 4)

5. Wikipedia

- https://en.wikipedia.org/wiki/WannaCry_ransomware_attack

Used for: Overview, timeline of attack (Section 1, Section 2)

6. CISA (TA17-132A)

- https://www.cisa.gov/news-events/alerts/ta17-132a

Used for: IOCs, YARA guidance, detection recommendations (Section 7)

7. MITRE ATT&CK Framework

- https://attack.mitre.org/
- https://attack.mitre.org/software/S0366

Used for: TTP mapping (T1210, T1486, T1490, T1543.003, etc.) (Section 3, Section 4 , Section 10)

8. NIST SP 800-61

- https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf

Used for: Incident response lifecycle framework (Section 8)

9. NHS Digital Incident Report

- https://www.england.nhs.uk/long-read/case-study-wannacry-attack/
- https://www.england.nhs.uk/wp-content/uploads/2018/02/lessons-learned-review-wannacry-ransomware-cyber-attack-cio-review.pdf

Used for: Impact data - 70,000 devices, 19,000 appointments, £92 million (Section 6), Lesson learned (Section 11)

10. Bloomberg / Reuters / Wire

- https://www.bloomberg.com/news/articles/2017-05-18/the-wannacry-global-hack-could-have-been-much-much-worse
- https://www.reuters.com/article/technology/-wannacry-attack-shows-trend-toward-economic-cyber-threats-rising-regulatory-idUSKBN19C2RQ/
- https://thewire.in/tech/wannacry-and-the-challenge-of-international-cooperation-in-cyberspace

Used for: Business impact, financial losses, organizational damage (Section 6)

11. Napkin AI

- https://www.napkin.ai/

Used for: Attack workflow diagram (Section 5)

12. Various Security Vendors

- Multiple vendor security blogs (CrowdStrike, Mandiant, Symantec, etc.)

Used for: Prevention architecture recommendations (Section 9)

13. Original Work by Author

- KQL and Splunk detection queries.
- SIEM correlation logic
- Detection timeline reconstruction
- IOC table organization and categorization
- MITRE ATT&CK mapping interpretation (using MITRE framework as reference)
- Incident response procedures adapted from NIST framework
- Section 11 learnings and takeaways